Безпека комп'ютерних мереж

Лекція 6+. Сканування мереж (Network Scanning)

Питання

- Концепції сканування мереж
- Інструменти сканування
- Методи сканування
- Захоплення банерів
- Побудова діаграм мережі за допомогою інструментів виявлення мережі

Концепції сканування мереж

Мережним скануванням називають набір процедур, що застосовують для ідентифікації хостів, портів та служб у мережі

- **Сканування — це процес збору детальної інформації про ціль за допомогою складних та агресивних розвідувальних прийомів**
  - Це один з найважливіших етапів розвідки
  - У процесі сканування намагаються зібрати інформацію, зокрема, про конкретні IP-адреси, до яких можна отримати доступ через мережу, операційні системи та архітектуру системи, а також служби, що працюють на кожному комп'ютері
- **Мета сканування полягає у виявленні придатних для використання каналів зв'язку, дослідженні якомога більшої кількості доступних служб та відстеженні тих, які корисні для конкретних потреб**
- **На етапі сканування намагаються:**
  - знайти різні способи доступу до цільової системи
  - з'ясувати, чи є в цільовій системі помилки конфігурації

Типи сканування

Сканування мереж

Надає список IP адрес

- Це процедура ідентифікації активних хостів у мережі або для їх атаки, або для оцінки безпеки мережі

Сканування портів

Надає список відкритих портів та служб

- Це процес перевірки служб, що працюють на цільовому комп'ютері, шляхом надсилання послідовності повідомлень
- Включає зондування портів TCP та UDP на цільовій системі, щоб визначити, чи запущені певні служби
- Стан прослуховування певних портів надає інформацію про операційну систему та програми, які зараз використовуються

Сканування вразливостей

Показує присутність відомих слабких місць

- Це метод перевірки того, чи можна скомпрометувати систему шляхом виявлення її вразливостей
- Сканер вразливості складається з механізму сканування та каталогу, що включає перелік загальних служб з відомими вразливими місцями та загальними експлойтами
- Ці інструменти, як правило, націлені на уразливості, які могли би бути усунені шляхом безпечної конфігурації хостів

Цілі сканування мереж

- **Знайти активні хости мережі, IP-адреси та відкриті порти**
  - Використовуючи відкриті порти, можна визначити найкращий спосіб входу в систему
- **Дізнатися про служби, що працюють або прослуховуються в цільовій системі**
  - Це дає вказівку на можливість використання певних вразливостей для отримання доступу до цільової системи
- **Визначити конкретні програми чи версії певної послуги**
- **Дізнатися про операційну систему та системну архітектуру цілі**
  - Можна сформулювати стратегію атаки на основі вразливостей операційної системи
- **Визначити вразливі місця в будь-якій з мережних систем**
  - Це допомагає компрометувати цільову систему або мережу за допомогою різних експлоітів

Засоби сканування

- **Засоби сканування сканують та ідентифікують реальні хости, відкриті порти, запущені служби в цільовій мережі, інформацію про місцезнаходження, інформацію NetBIOS та інформацію про всі відкриті порти TCP та UDP**

Засіб сканування: nmap

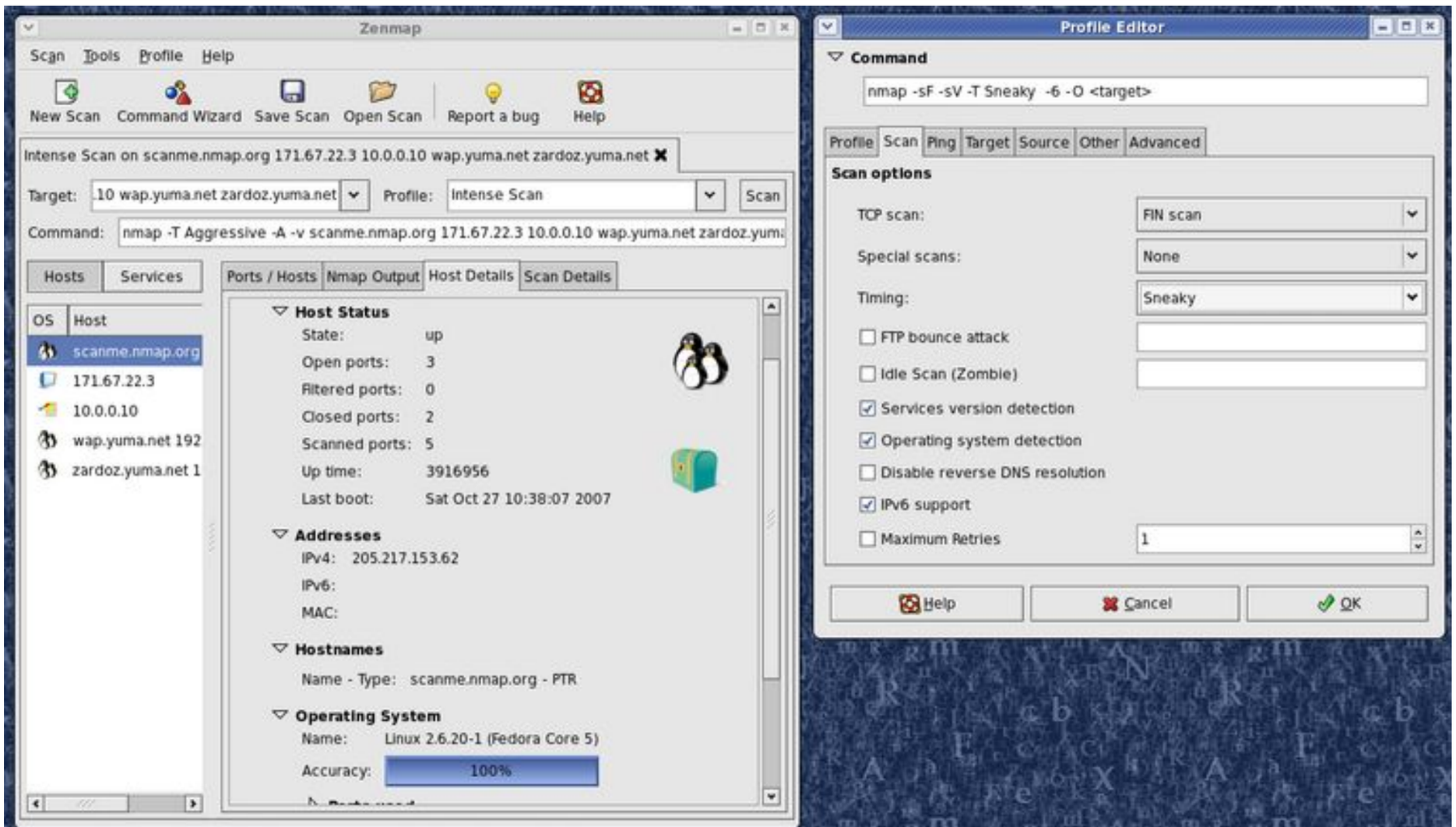
https://nmap.org

Nmap — це сканер для вивчення мережі

- **Дозволяє виявляти хости та служби в комп'ютерній мережі, створюючи тим самим "мапу" мережі**
  - Надсилає спеціально створені пакети цільовому хосту, а потім аналізує відповіді
- **Або адміністратор мережі, або зловмисник можуть використовувати цей інструмент для своїх конкретних потреб**
  - **Адміністратори мережі** — для інвентаризації мережі, управління графіками оновлення служб та моніторингу часу роботи хосту або служби
  - **Зловмисники** — для видобування такої інформації, як активні хости в мережі, послуги (назва програми та версія), тип фільтрів пакетів / брандмауерів, операційні системи та їх версії
- **Nmap включає:**
  - **Ncat** — гнучкий інструмент передачі даних, перенаправлення та налагодження
  - **Ndiff** — утиліта для порівняння результатів сканування
  - **Nping** — інструмент генерації та аналізу відповідей пакетів

- **Може сканувати величезні мережі з сотень тисяч машин**
- **Підтримує десятки передових методів картографування мереж, наповнених IP-фільтрами, брандмауерами, маршрутизаторами та іншими перешкодами**
- **Включає в себе безліч механізмів сканування портів (TCP та UDP), виявлення ОС, виявлення версій, ping sweep тощо**

Zenmap: графічний front-end для nmap



http://www.hping.org

Засіб сканування: Hping2/Hping3

- Hping2/Hping3 — це інструмент командного рядка для мережного сканування та створення пакетів протоколів TCP/IP, який надсилає exo-запити ICMP та підтримує протоколи TCP, UDP, ICMP та raw-IP
- Виконує аудит мережної безпеки, тестування брандмауера, виявлення MTU вручну, вдосконалене трасування маршруту, віддалене сканування (fingerprinting) ОС, віддалене вгадування часу безперервної роботи, аудит стеків TCP/IP та інші функції
- Має режим Traceroute, який дозволяє передавати файли прихованими каналами
- Може надсилати власні пакети TCP/IP і відображати цільові відповіді, як це робить програма ping з відповідями ICMP
- Обробляє фрагментацію, довільне тіло та розмір пакетів і використовує їх для передачі інкапсульованих файлів за підтримуваними протоколами
- Підтримує сканування з “idle host”

hping

- Визначає, чи працює хост, навіть коли хост блокує пакети ICMP
- Допомагає розширеному скануванню портів і тестує продуктивність мережі, використовуючи різні протоколи, розміри пакетів, TOS та фрагментацію
- Дозволяє визначати MTU вручну
- Використання за принципом “Firewalk” дозволяє виявляти відкриті порти за брандмауерами

Засіб сканування: NetScanTools Pro

Джерело: http://www.netscantools.com

- **NetScanTools Pro – це інструмент дослідження, який дозволяє виправляти, відстежувати, виявляти та детектувати пристрої у вашій мережі**
- **Ви можете легко збирати інформацію про локальну локальну мережу, а також про користувачів Інтернету, IP-адреси, порти тощо, використовуючи цей інструмент**
- **Ви можете знайти вразливі місця та відкриті порти у своїй системі**
- **NetScanTools Pro поєднує в собі понад 50 мережевих інструментів і утиліт, класифікованих за функціями, наприклад, активний, пасивний, DNS і локальний комп'ютер.**
  - Local Computer and General Information Tools: Provide details about your local computer’s network
  - Активні засоби виявлення та діагностики: використовуються для тестування та визначення місцезнаходження пристроїв, що підключені до вашої мережі
  - Засоби пасивного виявлення: відстежують діяльність пристроїв, підключених до вашої мережі, і збирають інформацію від третіх сторін
  - Засоби DNS: допомагають виявити проблеми з DNS
  - Засоби локального комп’ютера та загальної інформації: надають відомості про локальну мережу вашого комп’ютера

Переваги:

- **Процес збору інформації стає простішим і швидшим завдяки автоматизації використання багатьох мережевих інструментів**
- **Чітко створює звіти про результати у вашому веб-браузері**

Інші засоби сканування

- SuperScan (https://www.mcafee.com)
- PRTG Network Monitor (https://www.paessler.com)
- OmniPeek (https://www.savvius.com)
- MiTeC Network Scanner (http://www.mitec.cz)
- NEWT Professional (http://www.komodolabs.com)
- MegaPing (http://www.magnetosoft.com)
- Slitheris Network Discovery (http://www.komodolabs.com)
- TamoSoft's CommView (http://www.tamos.com)
- IP Scanner (https://community.spiceworks.com)

- IP-Tools (https://www.ks-soft.net)
- Network Scanner (http://www.10-strike.com)
- Global Network Inventory (http://www.magnetosoft.com)
- SoftPerfect Network Scanner (https://www.softperfect.com)
- Advanced Port Scanner (https://www.advanced-port-scanner.com)
- CurrPorts (http://www.nirsoft.net)
- Masscan (https://github.com)
- DRACNMAP (https://github.com)
- NEET (https://github.com)

Засоби сканування для мобільних терміналів

IP Scanner

Джерело: http://10base-t.com

- IP Сканер для iOS сканує вашу локальну мережу, щоб визначити ідентичність всіх її активних машин та Інтернет-пристроїв

Особливості:

- Вбудовані інструменти Ping, Portscan і WOL
- Перехід до рідного VNC, веб-браузера або будь-якої спеціальної служби безпосередньо з результатів сканування
- Настроювані параметри відображення для призначення назв і піктограм знайденим пристроям
- Можливість створювати власні категорії пристроїв із зображеннями
- Можливість експортувати, надсилати електронною поштою та роздруковувати результати сканування

Fing

Джерело: https://www.fing.io

- Fing — це мобільний застосунок для Android та iOS що сканує і надає повну інформацію про мережу, таку як IP адреси, MAC адреси, виробники пристроїв, та розміщення провайдера Інтернету

Особливості:

- Виявляє всі пристрої, підключені до мережі Wi-Fi
- Відображає MAC-адресу та виробника пристрою
- Повний пошук за IP-адресою, MAC-адресою, назвою, постачальником та примітками
- Wake On LAN: дозволяє вмикати ваші пристрої з мобільного телефону або планшета
- Ping і traceroute: оцінює продуктивність мережі
- Автоматичний пошук DNS і зворотний пошук
- Відстежує, коли пристрій перейшов у режим онлайн чи офлайн
- Запускає програми для певних портів, таких як браузер, SSH, FTP
- Відображає імена та властивості NetBIOS
- Підтримує ідентифікацію за IP-адресою для мостових мереж
- Сортує за IP-адресою, MAC-адресою, назвою, постачальником, станом та останньою зміною

Засоби конструювання пакетів

Colasoft Packet Builder

Джерело: http://www.colasoft.com

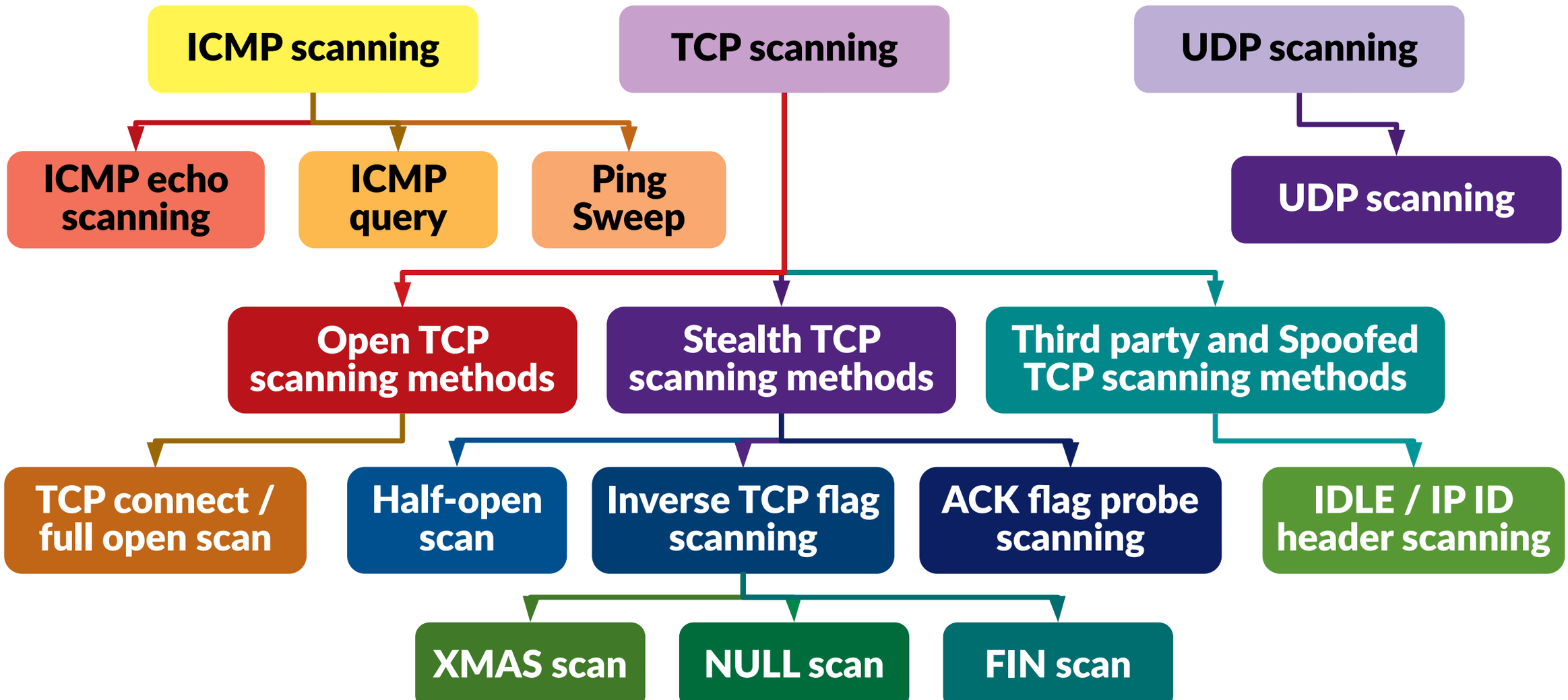
- **Colasoft Packet Builder — це інструмент, який дозволяє створювати власні мережеві пакети та допомагає фахівцям з безпеки оцінити мережу**
- **На додаток до створення пакетів, Colasoft Packet Builder підтримує збереження пакетів у файли пакетів і надсилання пакетів у мережу**
- **У Packet Builder є три види: список пакетів, редактор декодування та шістнадцятковий редактор**
- **Оператор може:**
  - обрати пакет TCP з наданих шаблонів і змінити параметри в редакторі декодування, шістнадцятковому редакторі або редакторі ASCII, щоб створити пакет;
  - відправити сконструйований пакет безпосередньо в мережу та керувати тим, як Colasoft Packet Builder надсилає пакети, вказуючи, наприклад, інтервал між кожним пакетом, час циклу та час затримки між циклами;
  - використовувати цей конструктор пакетів для створення фрагментованих пакетів для обходу мережевих брандмауерів і систем IDS;
  - засипати ціль дуже великою кількістю пакетів, що може призвести до атаки відмови в обслуговуванні

- **Засоби конструювання пакетів використовуються для створення та аналізу мережевого трафіку**
  - Типовим завданням є створення специфічних пакетів за допомогою прапорів TCP
- **Ці засоби створюють і надсилають потоки пакетів, використовуючи різні протоколи з різною швидкістю передачі**

До таких засобів, зокрема, належать:

- **NetScanTools Pro (https://www.netscantools.com)**
- **Ostinato (http://ostinato.org)**
- **WAN Killer (http://www.solarwinds.com)**
- **Packeth (http://packeth.sourceforge.net)**
- **LANforge FIRE (http://www.candelatech.com)**
- **Bit-Twist (http://bittwist.sourceforge.net)**
- **WireEdit (https://wireedit.com)**

Методики сканування



Сканування ICMP — перевірка активності систем

- **Сканування ICMP пропонує надсилати пакети ICMP до системи призначення для збору необхідної інформації про неї**
- **ICMP не має абстракції портів, і це не те саме, що сканування портів**
- **Корисно визначити, які хости в мережі запущені, перевіривши їх усі**
- **Пінг-сканування передбачає надсилання запитів ICMP ECHO на хост**
  - Якщо хост живий, він поверне відповідь ICMP ECHO
  - Це сканування корисно для пошуку активних пристроїв або визначення того, чи проходить ICMP через брандмауер
- **Можна надіслати запит ICMP ECHO на широкомовну адресу**
  - Хости UNIX/Linux відповіли б на такий запит, але хости Windows — ні

Nmap

- **Nmap використовує параметр -P для паралельного сканування ICMP**
- **Користувач може збільшувати кількість пінгів паралельно за допомогою параметра -L**
- **Може бути корисно налаштувати значення тайм-ауту ping за допомогою параметра -T**

ICMP Query

- **Інструмент UNIX ICMP query або ICMPush запитує системний час (щоб дізнатися системний часовий пояс), надсилаючи повідомлення ICMP типу 13 (TIMESTAMP)**
- **Мережева маска в конкретній системі також може бути визначена за допомогою повідомлень ICMP типу 17 (ADDRESS MASK REQUEST)**
  - Знайшовши маску мережі мережевої карти, користувач може визначити всі підмережі, що використовуються
  - Тоді користувач може націлюватися лише на одну конкретну підмережу і уникати використання широкомовних адрес
- **ICMP Query має опції запиту як часової позначки, так і маски адреси**

Ping Sweep — перевірка активності систем

- **Коли система виконує ping, вона надсилає один пакет запиту ICMP ECHO по мережі на певну IP-адресу**
  - Цей пакет містить 64 байти (56 байт даних і 8 байтів інформації заголовка протоколу)
- **Потім відправник чекає або прослуховує зворотний пакет від цільової системи**
  - Якщо з'єднання хороші і цільовий комп'ютер «живий», очікується пакет повернення ICMP ECHO
  - Це не буде так, якщо є збій у зв'язку, але можуть бути повернуті інші типи пакетів ICMP та надати додаткову інформацію
- **Пінг також:**
  - детально описує кількість часу, необхідного пакету, щоб здійснити повний прохід туди й назад, який називається «round-trip time»;
  - допомагає розпізнавати імена хостів

- Ping **sweep (також відомий як ICMP sweep) — це основний метод сканування мережі, який використовується для визначення діапазону IP-адрес, що відображаються на живих хостах (комп'ютерах).**
- **В той час коли один ping повідомить користувачеві, чи існує один вказаний хост-комп'ютер у мережі, ping sweep складається із запитів ICMP ECHO (тип 8), надісланих кільком хостам.**
- **Якщо вказаний хост активний, він поверне відповідь ICMP ECHO (тип 0)**

Засоби Ping Sweep

- **Angry IP Scanner (http://www.angryip.org)**
- **SolarWinds Engineer's Toolset (http://www.solarwinds.com)**
- **NetScanTools Pro (https://www.netscantools.com)**
- **Colasoft Ping Tool (http://www.colasoft.com)**
- **Visual Ping Tester (http://www. pingtester.net)**
- **OpUtils (https://www.manageengine.com)**

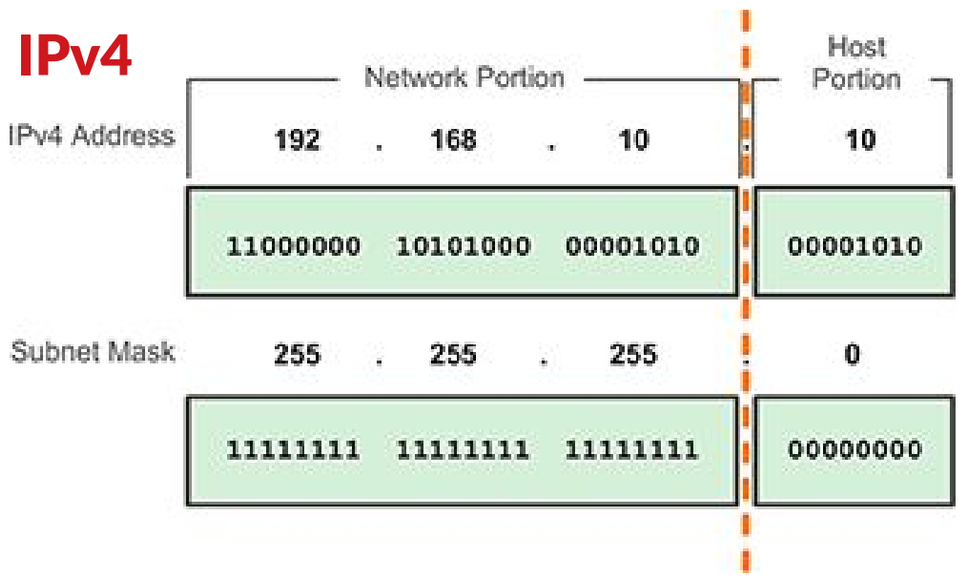
Сканування мереж IPv6

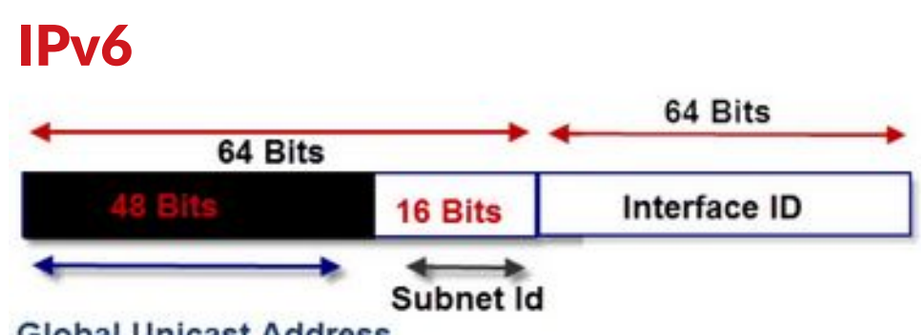
Проблема:

- **IPv6 збільшує розмір простору IP-адрес з 32 біт до 128 біт. Крім того, «хост-частина адреси» (ідентифікатор інтерфейсу) становить 64 біта**
  - З IPv4 типова підмережа має 254 (клас C) або 65534 (клас B) вузли
  - З IPv6 підмережа може складатися з 2^{64} (більше $4 \cdot 10^{18}$) вузлів (шалено величезна кількість! Ping sweep триватиме вічність!)
- **Деякі інструменти сканування не підтримують ping sweep в мережах IPv6**

Рішення:

- **Потрібно збирати IPv6-адреси з мережевого трафіку, журналів реєстрації або «Отримано від» та інших рядків заголовка в архівній електронній пошті або новинах Usenet, щоб ідентифікувати IPv6-адреси для подальшого сканування портів**
- **Якщо вдається скомпрометувати один хост підмережі, то можна перевірити локальну багатоадресну адресу посилання "всі хости", якщо номери хостів є послідовними, або використовувати будь-яку звичайну схему**



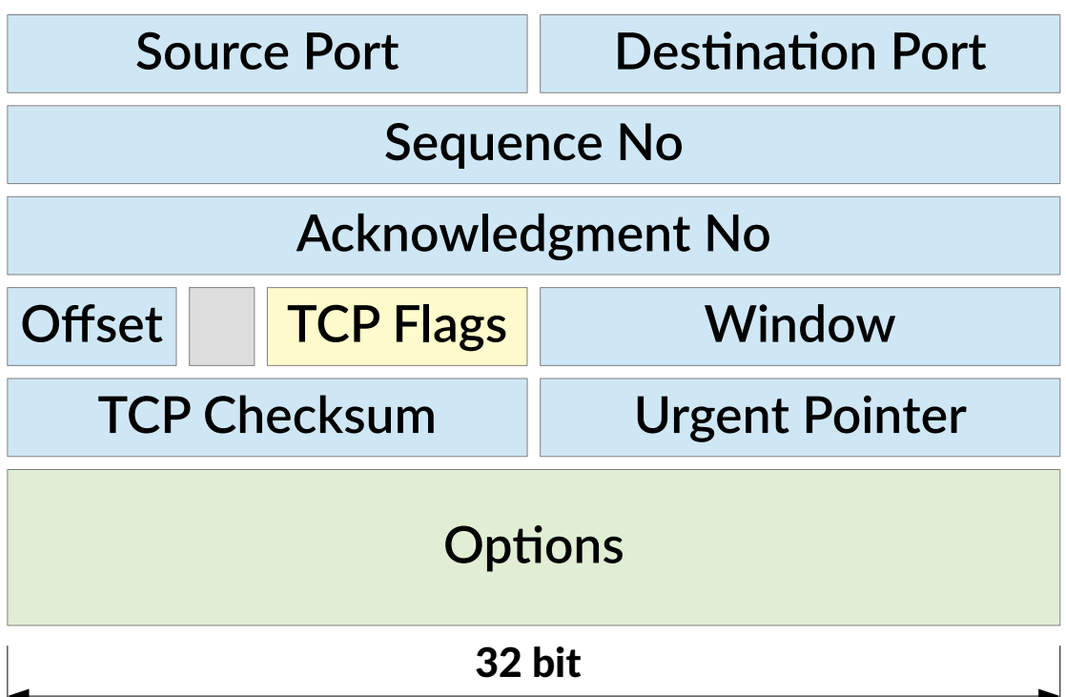


IPv6 Address Structure

Заголовок TCP та прапорці

Є 8 керівних прапорців TCP.
4 з цих прапорців (SYN, ACK, FIN і RST) керують встановленням, підтримкою та припиненням з'єднання,
2 прапорці (PSH і URG) надають інструкції системі,
2 інші прапорці контролюють уникнення перевантажень.

TCP Header

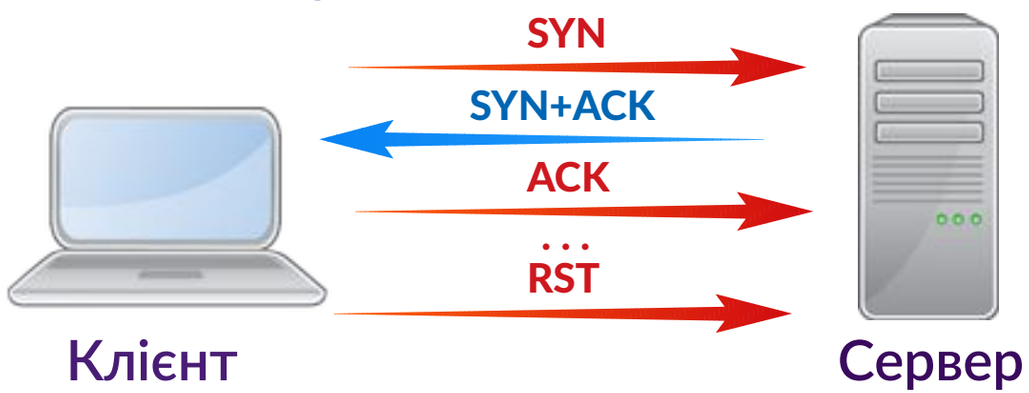


Прапор	Значення
SYN Synchro-nize	Повідомляє про передачу нового порядкового номера і, як правило, представляє встановлення з’єднання
ACK Acknow-ledgment	Підтверджує отримання передачі та визначає наступний очікуваний порядковий номер
PSH Push	Вказує на те, що віддалена система повинна інформувати програму-отримувач про буферизовані дані, що надходять від відправника
URG Urgent	Наказує системі якнайшвидше обробляти дані, що містяться в пакетах
FIN Finish	Встановлюється для оголошення, що хост більше не надсилатиме дані до віддаленої системи та готовий завершити з’єднання
RST Reset	Розриває з’єднання у відповідь на помилку

TCP Connect / Full Open Scan

- **TCP Connect/Full Open Scan є однією з найнадійніших форм TCP-сканування**
- **Під час сканування TCP Connect, системний виклик TCP connect() операційної системи намагається відкрити з'єднання з кожним цікавим портом на цільовій машині.**
  - Якщо порт прослуховує, виклик connect() приведе до успішного з'єднання з хостом на цьому конкретному порту
  - Інакше він поверне повідомлення про помилку про те, що порт недоступний
- **Здійснення окремого виклику connect() для кожного цільового порту лінійним способом займе багато часу при повільному з'єднанні**
- **Можна прискорити сканування, використовуючи багато сокетів паралельно**

TCP Connect scan завершує процедуру рукостискання (three-way handshake) з цільовою машиною



- **Недоліком цього типу сканування є те, що його легко виявити та відфільтрувати**
- **Журнали цільової системи розкриватимуть з'єднання**
- **Цей тип сканування не вимагає прав суперкористувача**

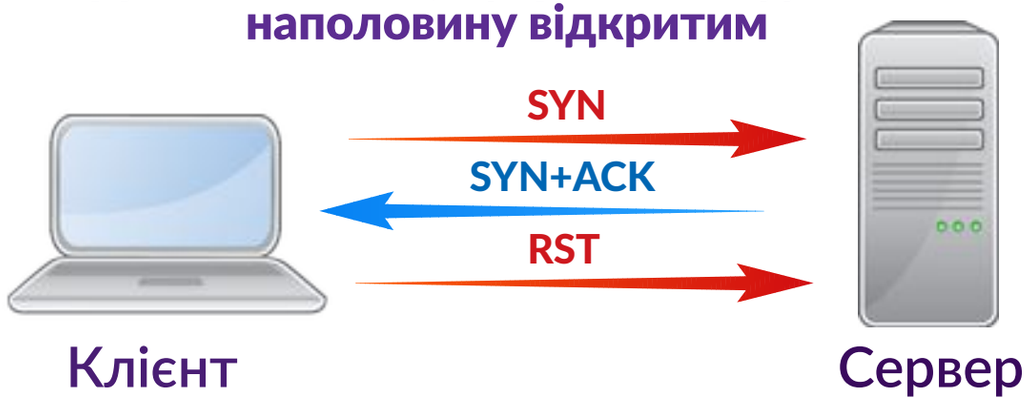
Stealth Scan (Half-open Scan)

Процес прихованого сканування

1. Клієнт надсилає один пакет SYN на сервер на відповідному порту
2. Якщо порт відкритий, згодом сервер відповідає пакетом SYN/ACK
3. Якщо сервер відповідає пакетом RST, то віддалений порт перебуває в «закритому» стані
4. Клієнт надсилає пакет RST, щоб закрити ініціалізацію, перш ніж з’єднання може бути встановлено

Методи прихованого сканування використовують для того, щоб обійти правила брандмауера, механізм реєстрації та сховатися, як зазвичай, під мережним трафіком

Приховане сканування включає скидання TCP-з'єднання між клієнтом і сервером до завершення триходової процедури рукостискання, що робить з'єднання наполовину відкритим



- Напіввідкрите сканування також називається «скануванням SYN», оскільки воно надсилає лише пакет SYN. Він частково відкриває з’єднання, але зупиняється на півдорозі
- Це не дозволяє службі сповіщати про вхідне з’єднання. Таким чином, TCP SYN або напіввідкрите сканування є прихованим методом сканування портів

Inverse TCP Flag Scanning

- Механізми безпеки, такі як брандмауери та IDS, виявляють пакети SYN, надіслані на чутливі порти цільових хостів
- Такі програми, як Synlogger і Courtney, дозволяють реєструвати спроби SYN сканування
- Інколи пробні пакети зі встановленими «неочікуваними» прапорцями TCP можуть пройти через фільтри непоміченими, залежно від встановлених механізмів безпеки
- Для цього надсилають пакети TCP з встановленим прапорцем TCP (FIN, URG, PSH) або без прапорців
- Відповідно до RFC 793, коли порт відкритий, той, хто сканує, не отримує відповіді від хоста, тоді як коли порт закритий, він або вона отримує RST/ACK від цільового хоста.

Типові конфігурації прапорців, що застосовуються для сканування, включають:

- **FIN** probe — встановлено **TCP прапорець FIN**
- **XMAS** probe — встановлено **TCP прапорці FIN, URG і PSH**
- **NULL probe — не встановлено жодних TCP прапорців**
- **SYN/ACK probe**

!

- Оскільки операційні системи, такі як Windows, повністю ігнорують стандарт RFC 793, ви не можете побачити відповідь RST/ACK при підключенні до закритого порту на цільовому хості
- Однак цей метод ефективний при використанні з операційними системами на базі UNIX

ACK Flag Probe Scanning

Під час сканування на віддалений пристрій надсилають TCP-пакети із встановленим прапором ACK, а потім аналізують інформацію заголовка (поля TTL та WINDOW) отриманих RST-пакетів, щоб дізнатися, відкритий чи закритий порт

Категорії сканування ACK Flag Probe:

- **Сканування ACK flag probe на основі TTL**
  - Спочатку потрібно надіслати пакети ACK (кілька тисяч) на різні порти TCP, а потім проаналізувати значення поля TTL отриманих RST-пакетів
  - Якщо значення TTL пакета RST на певному порту менше граничного значення 64, то цей порт відкритий
- **Сканування ACK flag probe на основі WINDOW**
  - Коли всі порти повертають одне й те саме значення TTL, спочатку потрібно відправити пакети ACK (кількість тисяч) на різні порти TCP, а потім проаналізувати значення поля Window отриманих RST-пакетів.
  - Якщо значення WINDOW пакета RST на певному порту має ненульове значення, то цей порт відкритий

Переваги:

- **Цей тип сканування в більшості випадків може уникнути IDS**

Недоліки:

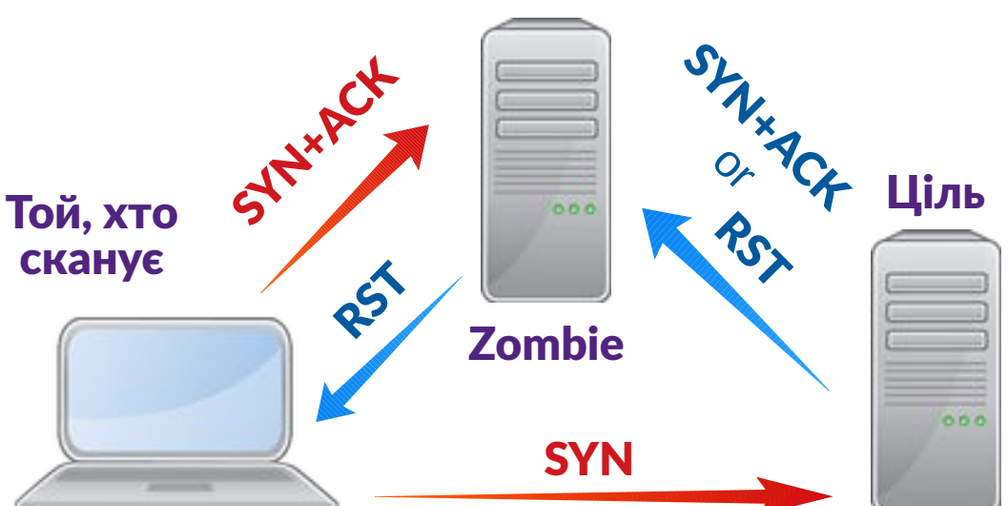
- **Сканування ACK flag probe використовує вразливості в стеку TCP/IP, що походить від BSD, тому воно ефективне лише для вразливих операційних систем.**
- **Це сканування дуже повільне**

Перевірка систем фільтрації цільових мереж

- **Надсилання пакета ACK із випадковим порядковим номером і відсутність відповіді від цілі означає, що порт фільтрується брандмауером із збереженням стану (statefull)**
- **Відповідь RST від цілі означає, що порт не фільтрується (statefull брандмауер відсутній)**

IDLE / IPID Header Scan (1/2)

- Кожен IP-пакет в Інтернеті має ідентифікаційний номер фрагмента (IPID); ОС збільшує IPID для кожного надісланого пакета, таким чином, зондування IPID дає тому, хто сканує, кількість пакетів, надісланих після попереднього зондування
- Машина, яка отримує неочікуваний пакет SYN+ACK, відповість RST
- Неочікуваний RST буде проігноровано



Крок 0

- Перш ніж виконувати Idle Scan, потрібно знайти придатного зомбі
- Зомбі, який призначає IPID пакетам поступово на глобальній основі, є придатним (або неактивним — idle) зомбі для виконання Idle Scan
- Чим менший інтервал часу для запиту/відповіді між парами той, хто сканує, — зомбі та зомбі — ціль, тим швидше сканування

Крок 1

- Той, хто сканує, надсилає пакет SYN+ACK на машину-зомбі, щоб перевірити її номер IPID
- Оскільки зомбі не очікує пакету SYN+ACK, він відхилить з’єднання, відправивши назад пакет RST
- Той, хто сканує, аналізує пакет RST, надісланий зомбі-машиною, щоб отримати IPID

IDLE / IPID Header Scan (2/2)

Крок 2

- Той, хто сканує, надсилає пакет SYN цільовій машині на порт, який він хоче перевірити, підробляючи IP-адресу зомбі

Порт закритий

- Отримавши пакет SYN від того, хто сканує, ціль відповість RST
- Зомбі залишиться бездіяльним, не вживаючи жодних подальших дій

Порт відкритий

- Ціль надішле пакет SYN+ACK до зомбі, щоб продовжити трикрокове рукостискання
- Оскільки зомбі не очікував пакету SYN+ACK від цільової машини, він відповість пакетом RST

Крок 3

- Той, хто сканує, знову повторює крок 1, надсилаючи пакет SYN+ACK зомбі, щоб перевірити номер IPID

- Якщо IPID збільшився на 1, це означає, що зомбі не надсилав жодних IP-пакетів після перевірки кроку 1
- Це означає, що порт на цільовій машині був закритий

- Якщо IPID збільшився на 2, це означає, що зомбі вже відправив IP-пакет; ймовірно, це був RST-пакет до цілі
- Це означає, що порт на цільовій машині був відкритий

Таким чином, використовуючи Idle Scan, той, хто сканує, може знайти відкриті порти та служби на цільових машинах, підмінивши свою IP-адресу на IP-адресу зомбі

UDP Scanning

Для сканування UDP немає процедури, подібної до процедури рукостискання, як в TCP
Якщо пакет UDP надіслано на відкритий порт, система не відповість повідомленням
Якщо порт UDP закритий, система має відповісти повідомленням ICMP «порт недосяжний»
Шпигунські програми, трояни та інші шкідливі програми використовують порти UDP

- **Коли ви надсилаєте пакет на закритий порт UDP, більшість хостів надсилає помилку ICMP_PORT_UNREACH**
  - Таким чином, ви можете визначити, що порт НЕ відкритий
- **Доставка пакетів UDP або помилок ICMP не гарантується**
  - Таким чином, сканери UDP такого типу повинні реалізовувати повторну передачу пакетів, які здаються втраченими, інакше втрачений трафік може бути інтерпретований як відкриті порти
- **Для сканування UDP потрібен привілейований доступ; отже, цей параметр сканування доступний лише в системах з відповідними правами користувача**
- **Цей метод сканування повільний, оскільки він обмежує частоту повідомлень про помилки ICMP як компенсацію для машин, які застосовують RFC 1812 розділ 4.3.2.8**
- **Операційні системи на базі Microsoft зазвичай не мають обмеження швидкості ICMP, тому це сканування працює дуже ефективно на пристроях на базі Windows**

SSDP та List Scanning

List Scanning

- **Під час сканування списку виявлення активного мережевого хоста є непрямим**
- **Сканування списку просто генерує та друкує список IP-адрес/імен без фактичного пінгування або перевірки хостів**
- **У результаті сканування списку показує всі IP-адреси як «не скановані» (0 хостів)**
- **За замовчуванням Nmap все ще виконує зворотне визначення DNS на кожному хості для вивчення їх імен**
- **Переваги:**
  - Сканування списку може виконати хорошу перевірку працездатності
  - Сканування списку виявляє неправильно визначені IP-адреси в командному рядку або у файлі параметрів

SSDP Scanning

- **SSDP (Simple Service Discovery Protocol) — це мережевий протокол, який зазвичай спілкується з машинами за допомогою маршрутизованих адрес багатоадресної розсилки IPv4 або IPv6**
- **Служба SSDP керує зв’язком для функції універсального підключення й роботи (Universal Plug and Play — UPnP)**
- **Зазвичай це працює, коли машина не схована за брандмауером**
- **Служба SSDP відповість на запит, надісланий через широкомовні адреси IPv4 або IPv6**
- **Ця відповідь містить інформацію про пов’язану з нею функцію Universal Plug and Play (UPnP)**
- **Той, хто сканує, використовує сканування SSDP для виявлення вразливостей UPnP, які можуть дозволити йому запустити переповнення буфера або DoS-атаки**
- **Той, хто сканує, може використовувати інструмент виявлення інформації UPnP SSDP M-SEARCH, щоб перевірити, чи машина вразлива до експлойтів UPnP**

Захоплення банерів

Захоплення банера (Banner grabbing) або OS fingerprinting — це метод, який використовується для визначення операційної системи, яка працює на віддаленій цільовій системі

Існує два типи захоплення банерів: активне та пасивне

Active Banner Grabbing

- **Спеціально створені пакети надсилаються на віддалену ОС, а відповіді записуються, формуючи так заний “відбиток пальця” — fingerprint**
- **Потім відповіді порівнюються з базою даних для визначення ОС**
- **Відповіді різних операційних систем відрізняються через відмінності в реалізації стеку TCP/IP**
  - Найбільш інформативними є TTL і розмір вікна TCP, отримані з першого IP-пакета в сеансі TCP

Passive Banner Grabbing

- **Захоплення банера з повідомлень про помилки**
  - Повідомлення про помилки надають таку інформацію, як тип сервера, тип ОС та засіб SSL, який використовується цільовою віддаленою системою
- **Прослуховування мережного трафіку**
  - Захоплення та аналіз пакетів від цілі дозволяє зловмиснику визначити ОС, яку використовує віддалена система
- **Захоплення банера з розширень сторінки**
  - Перегляд розширення в URL-адресі може допомогти визначити версію програми

Контрзаходи проти захоплення банерів

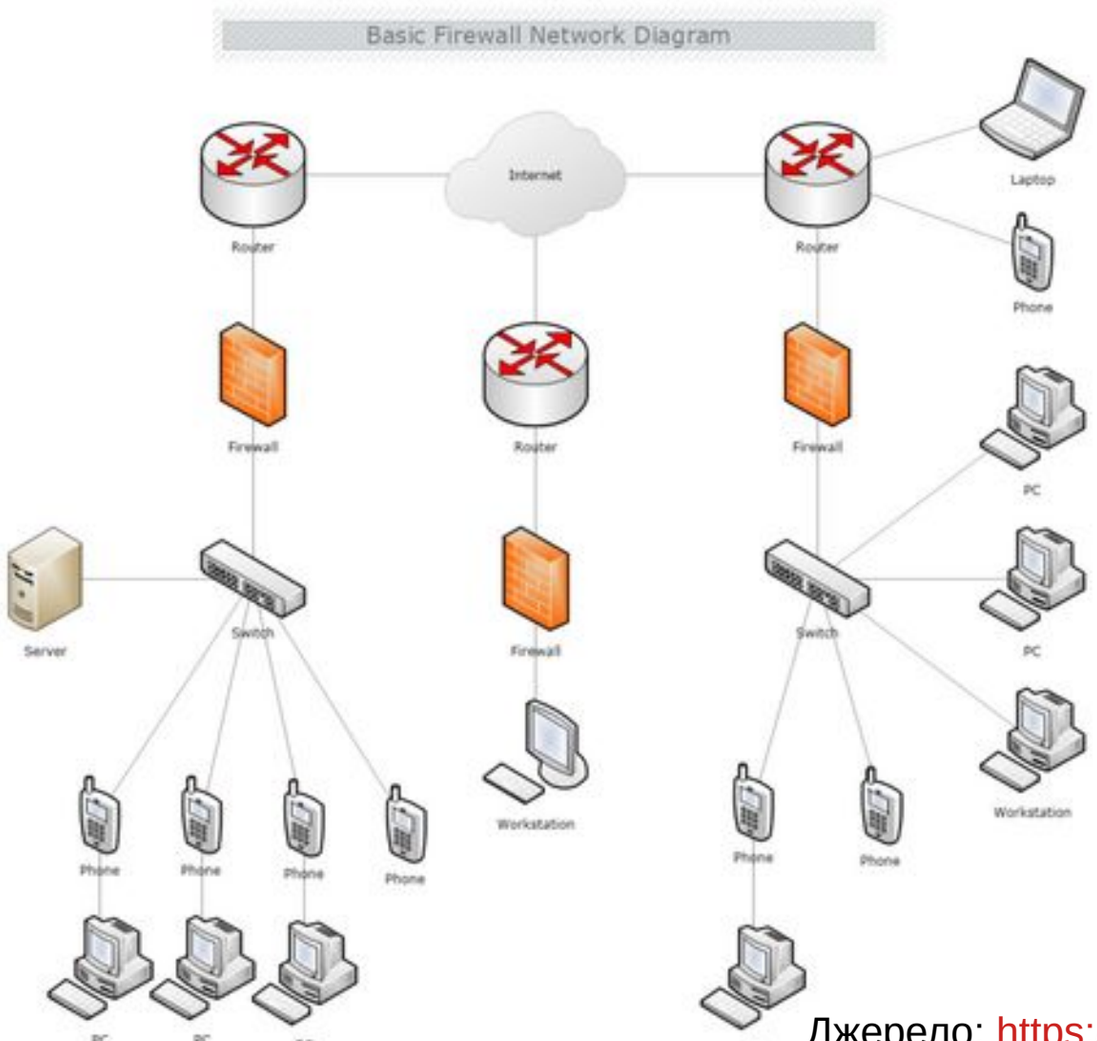
Вимкнення або зміна банера

- **Показуйте фальшиві банери, щоб ввести в оману або обдурити зловмисників**
- **Вимкніть непотрібні служби на хості мережі, щоб обмежити розкриття інформації**
- **Використовуйте інструменти ServerMask (https://www.port80software.com), щоб вимкнути або змінити інформацію про банер**
  - ServerMask видаляє непотрібні дані HTTP-заголовоку та відповідей і маскує сервер, надаючи фальшиві підписи
  - Він також надає вам можливість виключити розширення файлів, такі як .asp або .aspx, і чітко вказує, що сайт працює на сервері Microsoft
- **Apache 2.x з модулем mod_headers: використовуйте директиву у файлі httpd.conf, щоб змінити інформацію банеру набір заголовків Server "New Server Name”**
  - Або змініть рядок ServerSignature на ServerSignatureOff у файлі httpd.conf

Приховування розширень файлів з веб-сторінок

- **Змініть зіставлення програм, наприклад .asp на .htm або .foo тощо, щоб замаскувати ідентичність серверів**
- **Користувачі Apache можуть використовувати директиви mod_negotiation**
- **Користувачі IIS використовують такі інструменти, як PageXchanger, щоб керувати розширеннями файлів**
- **Примітка. Краще, якщо розширення файлів не використовуються взагалі**

Побудова діаграм мереж



- Складання діаграми мережі допомагає визначити топологію або архітектуру цільової мережі
- Діаграма мережі також допомагає відстежити шлях до цільового хосту в мережі та дає змогу зрозуміти положення брандмауерів, IDS, маршрутизаторів та інших пристроїв керування доступом
- Коли той, хто атакує, отримає цю інформацію, він може спробувати знайти вразливості або слабкі місця цих механізмів безпеки
- Потім він може проексплуатувати ці недоліки безпеки, щоб знайти шлях до мережі цілі
- Діаграма мережі також допомагає адміністраторам мережі керувати своїми мережами
- Засоби відображення мережі використовують, щоб накреслити діаграми цільових мереж

Джерело: https://www.mydraw.com

Засоби виявлення та побудови діаграм мереж

Network Topology Mapper

Джерело: http://www.solarwinds.com

Засіб Network Topology Mapper дозволяє автоматично виявляти та створювати мережеву карту цільової мережі

Він також може відображати багаторівневі з'єднання, такі як дані топології рівня 2 та рівня 3 OSI (наприклад, відображення з'єднань комутатор-коммутатор, комутатор-вузол і комутатор-маршрутизатор)

Він може відстежувати зміни в мережі та дозволяти користувачеві здійснювати управління інвентаризацією апаратних і програмних засобів

Особливості:

- Автоматично виявляє всю мережу та створює вичерпні та детальні карти мережі
- Експортує діаграми мережі у формати Microsoft Office® Visio®, Orion Network Atlas, PDF та PNG
- Дозволяє безпосередньо вирішувати питання відповідності PCI та іншим нормам, які вимагають підтримки актуальної схеми мережі
- Виконує багаторівневе виявлення мережі, щоб створити інтегровану мережеву карту рівня 2 та рівня 3, яка містить детальну інформацію про пристрої
- Автоматично виявляє нові пристрої та зміни топології мережі за допомогою запланованого сканування мережі

Деякі із засобів виявлення та побудови діаграм мереж:

- OpManager (https://www.manageengine.com)
- The Dude (https://www.mikrotik.com)
- NetSurveyor (http://nutsaboutnets.com)
- NetBrain (https://www.netbraintech.com)
- Spiceworks Inventory (https://www.spiceworks.com)
- LANState (http://www.10-strike.com)
- Friendly Pinger (http://www.kilievich.com)
- WhatsConnected (https://www.ipswitch.com)
- Lan-Secure Switch Center (http://www.lan-secure.com)
- Intermapper (https://www.helpsystems.com)
- SteelCentral NetAuditor (https://www.riverbed.com)
- IPsonar (http://www.lumeta.com)

Засоби виявлення мереж для мобільних пристроїв

Scany

Джерело: http://happymagenta.com

- **Scany, програма мережного сканування для iPhone та iPad, сканує локальну мережу, мережі Wi-Fi, веб-сайти, відкриті порти, виявляє мережні пристрої та видобуває інформацію про мережу**
- **Він підтримує низку мережевих протоколів і анті-стелс технологій**
- **Це багатофункціональний мережний інструмент для пошуку підключених пристроїв, пошуку детальної інформації про пристрої, усунення несправностей мережі, сканування портів, тестування безпеки мережі та брандмауерів**

Особливості:

- **Сканує як локальну мережу, так і Інтернет**
- **Сканує будь-яку IP-адресу або діапазон мережі**
- **Перегляд імен хостів Bonjour**
- **Перегляд імен хостів Windows (NetBIOS, Samba)**
- **Перегляд імен пристроїв (UPnP, SSDP, DLNA)**
- **Визначає країну походження та власника мережі**
- **Перегляд діапазону мережі та номера автономної системи**
- **Перегляд MAC-адреси та постачальника обладнання**
- **Пробудження через локальну мережу або Wi-Fi (за MAC-адресою)**
- **Пробудження через Інтернет (за допомогою відповідних маршрутизаторів)**
- **Ping/Trace хостів з інтегрованими інструментами**
- **Імена хостів WHOIS, IP-адреси, ASN**
- **Знає WiFi, VPN, 3G/EDGE та зовнішні IP-адреси**
- **Перевіряє ICMP, TCP та UDP**
- **Швидше асинхронне мережне введення-виведення**
- **Працює з Wi-Fi, 3G, EDGE і GPRS**

Засоби виявлення мереж для мобільних пристроїв

Мережний “Swiss-Army-Knife”

Джерело: http://foobang.weebly.com

Мережний «Swiss-Army-Knife» - це програма для iPhone для виконання ряду завдань, зазначених нижче:

- Розрахувати підмережу IPv4 (класову та безкласову) та всю пов’язану дійсну інформацію про підмережу
- Знайти оффлайн апаратну MAC-адресу для пошуку організації та навпаки
- Виконати одиничний/пакетний пошук доменного імені: для списку доменних імен можна знайти еквівалентну IP-адресу
- Виконати пошук WHOIS безпосередньо з пристрою. Пошук WHOIS дозволяє запитати список NIC для отримання детальної інформації
- Перегляд номера порту IANA оффлайн: визначає для імені присвоєний IANA номер порту і навпаки
- Пошук домену IANA верхнього рівня: визначає, у яких країнах домен закінчується на .cz, .cv, .su тощо
- IP-адреса Wi-Fi мого пристрою: дозволяє ідентифікувати IP-адресу Wi-Fi вашого локального пристрою

Деякі інші засоби виявлення мереж для мобільних пристроїв:

- PortDroid Network Analysis (https://play.google.com)
- NetX - Network Discovery Tools (https://play.google.com)
- Network Mapper (https://play.google.com)
- Fing - Network Tools (https://www.fing.io)
- ezNetScan (https://play.google.com)